

YOUR WEEKLY MICROSOFT SENTINEL BRIEFING

Sentinel Weekly

NO. 07 • SEPTEMBER 3 - 9, 2026

A quiet week on the release notes, a loud one on the threat research.

NEW EVERY THURSDAY • CURATED BY PHILLIPE CHAVES DE LIMA

50.81 N • 7.15 E

A quiet week on the release notes, a loud one on the threat research: attackers spent it impersonating your helpdesk, hiding text your mail filter cannot see, and turning passkey rollouts into a phishing pretext.

Subscribe on [LinkedIn](#) to get the next edition every Thursday.

On the radar this week

- **Passkey-themed social engineering leads to identity and cloud compromise** (*Microsoft Security Blog, September 9*): Storm-3121 and Storm-3032 use your passkey rollout as the story. A phone call about an urgent authentication update, a spoofed sign-in page, an adversary-in-the-middle session capture, then a fresh MFA method registered on the account and hours of Microsoft Graph reconnaissance. Ten hunting queries ship with it.
- **ASCII smuggling crosses over from AI prompt injection to phishing evasion** (*Microsoft Security Blog, September 3*): Invisible Unicode Tag characters, the ones AI researchers found hiding instructions from humans, are now being dropped inside finance keywords to break literal string matching in mail filters. About 150 disposable sender domains, routed through a legitimate marketing platform.
- **Threat Matrix: Mapping threats across cloud web applications** (*Microsoft Security Blog, September 9*): A new ATT&CK-aligned matrix for cloud-hosted web apps and serverless, spanning eleven tactics from Resource Development to Impact. Useful as a coverage checklist if App Service and Functions sit inside your detection scope.

- **Impersonating IT support: how threat actors turn a remote session into enterprise-wide access**

(*Microsoft Security Blog, September 2*): Catching up on one that landed two days before this window opened and deserves the space. External Teams chat, a remote support session, a silent MSI, a portable Node.js runtime, then WinRM to the domain controller.

In this edition

Shipped and live now

Nothing. That is the honest answer, and it is worth stating plainly rather than padding around it.

The Microsoft Sentinel What's new page on Learn has not moved since August 24. The Microsoft Sentinel Blog's last post was the August monthly roundup on August 31. The Defender XDR blog last published on September 1, two days before this window opened, and the Entra September roundup went up the same day. Security Copilot has been silent on its blog since March. No GA announcements, no new previews, no status changes in the September 3 to 9 window on any of the four product lines this newsletter tracks.

What did move is the part nobody blogs about: the Azure-Sentinel content repository. In the window, the Okta Single Sign-On V2 connector got pagination handling to stop it drowning in HTTP 429 responses (PR 14992), a Rubrik Security Cloud CCF connector landed (PR 15046), the DNS Essentials solution was repackaged with an updated workbook and a new custom parser, and ASIM picked up more ingest-time parsers (PR 15080), entity keys across the schemas (PR 14628), and a field type fix in WebSessionNative (PR 14942). If you run any of those connectors, that is your actual changelog for the week. It lives in the Solutions folder of the Azure-Sentinel repo on GitHub, not in any What's new page.

This is the fourth thin week in a row for Sentinel product news. The August wave ran August 5 to 11 and is already in Editions 3 and 4. Whatever is coming next is not out yet.

Agentic SOC watch

The ASCII smuggling story is the one to sit with, because of the direction it travels.

The technique started in AI security research. Unicode Tag characters in the U+E0000 to U+E007F block render as nothing to a human reader but survive as real characters in the text a model receives, which made them a neat way to hide prompt injection payloads in plain sight. This campaign takes the same characters and points them at a much older target: the keyword matcher in an email security stack. Split "funding" with an invisible U+E0020 in the middle and a literal signature no longer fires, while the recipient sees a perfectly normal word.

Activity peaked between February 9 and May 15, 2026, ran on a strict weekday-on, weekend-off schedule, and reached multi-million message days at its height. Microsoft's guidance compresses to four words: normalize before you match. Strip invisible Unicode at the front of the pipeline, then run your detections against the normalized string.

The wider lesson for anyone building agentic detection content is that AI-specific attack research is not staying in its lane. Techniques developed to manipulate models are being retargeted at conventional controls, because the underlying weakness (a parser and a human seeing different things) was never AI-specific to begin with.

Alongside it, Microsoft published [How to secure edge AI in customer-owned environments](#) (*Microsoft Security Blog, September 4*), which is guidance rather than research, and argues a position worth arguing: model output should recommend actions, not authorize them. Deterministic mediation, runtime attestation and artifact provenance, with sensitive assets bound to approved runtimes under renewable verification leases. If you are being asked to sign off on an agent that can act in production, that is a usable set of gates.

Next door: Defender XDR and Entra

Two intrusion write-ups this fortnight describe the same opening move from different angles, and reading them together is more useful than reading either alone.

In the September 2 report, the approach comes over Microsoft Teams from an external tenant, with the actor posing as helpdesk. The victim is talked into a remote support session, PowerShell pulls an MSI from Azure Blob Storage under a name like "devfix", `msiexec /qn` installs it silently, and a portable Node.js runtime is unpacked into a randomized LocalAppData folder to run an encrypted JavaScript implant carried in files with extensions like `.tmp` and `.cfg`. Persistence is an unglamorous `HKCU\Run` key named "EdgeUpdate". Command and control is randomized HTTPS long-polling, with a dormant fallback that reads its C2 address out of an Ethereum smart contract. Lateral movement is WinRM on TCP 5985, aimed at domain controllers and certificate authorities.

In the September 9 report, the approach is a phone call about passkeys and the endgame is entirely identity-side: AiTM or device code capture of a session, then an attacker-controlled authenticator registered as a new MFA method, then systematic Graph enumeration of users, roles, applications, sites and mailboxes, then bulk collection out of SharePoint, OneDrive and Exchange. The exfiltration tooling gives itself away with a `python-httpx` user agent.

The common thread is that neither needs a vulnerability. Both need a person to believe that IT is on the phone. The detection value sits in what happens immediately after: a new strong authentication method appearing on an account, and a single identity touching several distinct Graph reconnaissance categories inside half an hour. Both are queryable today, the first from `CloudAppEvents`, the second from [GraphApiAuditEvents](#) (*Microsoft Learn*), which records method, URI, status code, calling identity and source IP for Graph requests in your tenant. If you have not built anything on that table yet, this write-up is a good excuse.

One query to steal

Hunting the ASCII smuggling trick directly. Invisible Unicode Tag characters have essentially no legitimate use in inbound mail subjects, which makes this an unusually high-signal thing to look for.

```
// illustrative, validate in your workspace first
// Invisible Unicode Tag characters (U+E0000 to U+E007F) in inbound mail.
// Same characters used to hide prompt injection from human readers,
// reused here to break keyword matching in mail filters.
let TagChars = @"[\x{E0000}-\x{E007F}]";
EmailEvents
| where Timestamp > ago(7d)
| where EmailDirection == "Inbound"
| where Subject matches regex TagChars
  or SenderDisplayName matches regex TagChars
| extend HiddenCharCount = countof(Subject, TagChars, "regex")
| summarize Messages = count(),
  Recipients = dcount(RecipientEmailAddress),
  MaxHidden = max(HiddenCharCount),
  SampleSubject = take_any(Subject)
  by SenderMailFromDomain, DeliveryAction, bin(Timestamp, 1d)
| where Messages >= 5
| order by Messages desc
```

Two things to know before you run it. First, keep the character class to the Tags block: widening it to the zero-width characters people actually use (U+200B, U+200D) will bury you in newsletter traffic and emoji sequences. Second, `DeliveryAction` in the grouping is deliberate, because a sender domain whose messages are landing in the inbox rather than being blocked is the row you want to look at first.

That's Edition 7

A week with no product news is still a week worth reading if you point the time somewhere useful. This one goes to the mail pipeline and the MFA registration event.

If you have already built detections on `GraphApiAuditEvents`, I would like to hear what is working. Drop it in the comments.

Never miss an edition: [subscribe to Sentinel Weekly on LinkedIn](#).

PDF archive of this edition: github.com/PhillipeChaves/sentinel-weekly

Curated by Phillipe Chaves de Lima. New every Thursday.